

PROJECT 01 · EMAIL SECURITY & THREAT INVESTIGATION

Case File: CA-ETI-01 | Analyst: Aditya Rao / Investigating SOC Analyst

1. Executive Summary

Following flagged unusual activity and a suspected fraud attempt in the mailbox of Mr. Aditya Rao, Senior Finance Executive at Solvex Industries Pvt. Ltd., an in-depth forensic threat investigation was conducted on all 13 recovered emails. The investigation evaluated technical headers (SPF, DKIM, DMARC, TLS), sender address discrepancies, Reply-To and Return-Path anomalies, embedded URLs, attachments (including macro-enabled and ZIP payloads), and social engineering indicators.

Overall Findings: Out of the 13 analysed emails, 5 were verified as safe/legitimate internal or trusted communications, while 8 were classified as high-risk or critical threats comprising Business Email Compromise (BEC), credential harvesting phishing, CEO fraud (whaling), advanced fee scams, and malicious attachment/macro malware delivery. Comprehensive Indicators of Compromise (IOCs) have been extracted, cross-verified using OSINT tools, and blocked.

2. Per-Email Findings Summary Table

Email No.	Subject / Context	Key Indicators	Risk Level
Email 01	Password Expiry Reminder (IT Helpdesk)	Valid internal domain (`solvexindustries.com`), SPF/DKIM/DMARC Pass, TLS 1.3.	SAFE
Email 02	Mailbox Storage FULL (IT Support Desk)	Typosquatted domain (`solvex-industries-helpdesk.com`), failed auth, Russian cloud host (`193.41.77.108`), phishing link.	CRITICAL
Email 03	Invoice SI-4471 & Bank Details (Apex Steel)	Mismatched Reply-To (`accounts.payments@apexsteel-billing.com`), bank detail change request.	HIGH RISK (BEC)
Email 04	Revised Leave & WFH Policy (HR)	Internal domain (`solvexindustries.com`), SPF/DKIM/DMARC Pass, legitimate HR notice.	SAFE
Email 05	Immediate Wire Transfer (MD / Whaling)	Executive impersonation, spoofed domain (`gmail-corpmail.com`), free relay in Netherlands (`45.137.22.9`), no SPF.	CRITICAL
Email 06	Google Drive Shared File (Priya Menon)	Legitimate Google Drive notification (`drive-shares-noreply@google.com`), SPF/DKIM Pass.	SAFE
Email 07	Microsoft Unusual Sign-in (Lagos, Nigeria)	Typosquatted domain (`micros0ft-online.com`), failed auth, VPN exit node (`77.91.134.6`), credential harvesting link.	CRITICAL
Email 08	Senior Finance Role Job Offer (TalentBridge)	Suspicious `.zip` attachment (`JD_SeniorFinanceManager_Client.zip`, 2.4 MB) requesting PAN/salary slips.	HIGH RISK
Email 09	TallyPrime Cloud Renewal Invoice	Valid Tally domain (`tallysolutions.com`), SPF/DKIM Pass, explicit note 'no bank details changed'.	SAFE
Email 10	International Email Lottery (\$1M Win)	Advance fee scam, Yandex webmail (`yandex-mailer.com`), Dutch freehosting relay, failed auth, \$250 fee demand.	CRITICAL
Email 11	Quick request before flight (CFO Gift Cards)	CFO impersonation BEC, external Reply-To (`s.iyer.cfo.travel@outlook.com`), gift card scam demand.	CRITICAL
Email 12	Mandatory Security Training Reminder (InfoSec)	Internal InfoSec domain (`solvexindustries.com`), SPF/DKIM/DMARC Pass, legitimate training notice.	SAFE
Email 13	Pending Invoice & Challan (.docm Malware)	Failed SPF, shared hosting cluster (`41.203.88.17`), macro-enabled Word document (`.docm`), malicious download link.	CRITICAL

3. Detailed Email-by-Email Investigation & Evidence

Email 01 (IT Password Expiry Reminder - SAFE)

Analysis: Received from internal IT Helpdesk (`ithelpdesk@solvexindustries.com`) via internal mail server `mail.solvexindustries.com` (192.168.14.22). SPF, DKIM, and DMARC all passed with TLS 1.3 encryption. The message follows standard corporate password rotation policies and directs users to internal service portals. No suspicious links or attachments. Verdict: Safe.

Email 02 (Mailbox Storage FULL - CRITICAL PHISHING)

Analysis: Impersonates IT Support Desk using a typosquatted domain (`solvex-industries-helpdesk.com`). Envelope sender is `bounce@mail-secure-verify.net`, with Reply-To `recovery-team@mail-secure-verify.net`. Originating IP `193.41.77.108` belongs to a Russian static cloud provider. SPF, DKIM, and DMARC failed. Contains high-urgency social engineering threatening account suspension and a malicious credential harvesting URL (`hxxp://solvex-industries-helpdesk.verify-account-secure.com/...`). Verdict: Critical Phishing.

Email 03 (Invoice SI-4471 Bank Detail Change - HIGH RISK BEC)

Analysis: Purports to be from Apex Steel Traders (`ramesh.kulkarni@apex-steeltraders.co`). While technical headers pass for the sender domain, the **Reply-To** header (`accounts.payments@apexsteel-billing.com`) points to an unrelated billing domain. The email requests a wire transfer to a NEW bank account due to an 'internal banking audit'.

This is classic Vendor Impersonation / Business Email Compromise (BEC). Verdict: High Risk.

Email 04 (Revised Leave & WFH Policy - SAFE)

Analysis: Official HR broadcast from `hr@solvexindustries.com` detailing policy updates effective 15 July 2026. All technical authentication checks passed, internal mail server IP, no external links or attachments. Verdict: Safe.

Email 05 (Immediate Wire Transfer / Managing Director - CRITICAL BEC / WHALING)

Analysis: Impersonates Managing Director Rajeev Malhotra, but sent from a spoofed external domain (`rajeev.malhotra.md@gmail-corpmail.com`) via a Dutch free email relay (`45.137.22.9`). Zero SPF/DKIM/DMARC records. Demands an urgent international wire transfer of USD 18,500 and explicitly instructs the employee to keep it secret from Priya and Accounts. Classic CEO Fraud / Whaling. Verdict: Critical.

Email 06 (Google Drive Shared File - SAFE)

Analysis: Automated notification from Google Drive (`drive-shares-noreply@google.com`, IP 209.85.220.89) indicating colleague Priya Menon shared `Q1\_Vendor\_Compliance\_Report.xlsx`. SPF/DKIM/DMARC passed. Routine internal audit preparation. Verdict: Safe.

Email 07 (Microsoft Unusual Sign-in - CRITICAL PHISHING)

Analysis: Spoofed Microsoft security alert (`security-noreply@microsoft-online.com` using a zero '0' typosquat). Sent from a VPN exit node (`77.91.134.6` in Nigeria/VPN). All auth checks failed. Threatens account restriction and links to credential harvesting URL (`hxxp://login.microsoft-online.com/...`). Verdict: Critical Phishing.

Email 08 (Senior Finance Role Job Offer - HIGH RISK MALWARE)

Analysis: Recruiter email from `neha.kapoor.hr@talentbridge-recruiters.net` offering a 40% salary hike. Contains attached ZIP archive (`JD\_SeniorFinanceManager\_Client.zip`, 2.4 MB) requesting sensitive PII (PAN card, salary slips). ZIP files in recruitment contexts frequently contain malicious executables or scripts. Verdict: High Risk.

Email 09 (TallyPrime Cloud Renewal Invoice - SAFE)

Analysis: Legitimate renewal invoice from Tally Solutions (`billing@tallysolutions.com`, IP 203.0.113.44). Auth checks passed. Explicitly notes no bank details have changed, distinguishing it from fraudulent BEC invoices. Verdict: Safe.

Email 10 (International Email Lottery - CRITICAL SCAM)

Analysis: Advance fee lottery scam claiming USD 1,000,000 winnings. Sent from Yandex webmail via Dutch freehosting relay (`185.220.101.44`). Failed all auth checks. Demands \$250 processing fee and ID copy. Verdict: Critical Scam.

Email 11 (Quick Request Before Flight / CFO Gift Cards - CRITICAL BEC)

Analysis: CFO Suresh Iyer (`suresh.iyer@solvexindustries.com`) requests 5 Amazon gift cards of Rs. 5,000 each while boarding a flight. Although the envelope sender matches the company, the **Reply-To** routes to `s.iyer.cfo.travel@outlook.com`. Classic gift card scam exploiting executive authority and urgency. Verdict: Critical BEC.

Email 12 (Mandatory Security Training Reminder - SAFE)

Analysis: Internal InfoSec training reminder (`infosec@solvexindustries.com`) regarding Q3 awareness module due by 17 July 2026. All auth checks passed. Verdict: Safe.

Email 13 (Pending Invoice & Challan - CRITICAL MALWARE)

Analysis: Sent from Shree Ganesh Logistics (`accounts.receivable@shreeganesh-logistics.in`), but originating IP (`41.203.88.17`) is an unrelated shared hosting cluster. SPF failed. Contains macro-enabled Word document attachment (`Pending\_Invoice\_Challan\_Details.docm`, 1.1 MB) and malicious download link (`shreeganesh-logistics.in.invoice-view-secure.com`). Prompts user to enable macros, a primary malware delivery vector. Verdict: Critical Malware.

4. Consolidated Indicators of Compromise (IOCs)

The following IOCs were extracted across the malicious emails and must be blocked across firewalls, email gateways, and endpoint security controls:

IOC Type	Indicator Value	Source / Email Ref	Threat Description
Domain	solvex-industries-helpdesk.com	Email 02	Typosquatted domain used for fake IT helpdesk phishing.
URL	solvex-industries-helpdesk.verifyaccount-secure.com	Email 02	Credential harvesting phishing landing page.
IP Address	193.41.77.108 (RU)	Email 02	Russian static cloud hosting node hosting phishing infrastructure.
Email	accounts.payments@apexsteel-billing.com	Email 03	Fraudulent Reply-To address for vendor payment redirection (BEC).
Domain	gmail-corpmail.com	Email 05	Lookalike domain impersonating Managing Director (CEO fraud).
IP Address	45.137.22.9 (NL)	Email 05	Netherlands free email hosting relay used for whaling attack.
Domain	micros0ft-online.com	Email 07	Typosquatted domain (digit '0' for 'o') for Microsoft phishing.
IP Address	77.91.134.6 (VPN)	Email 07	VPN exit node masking phishing threat actor origin.
Filename	JD_SeniorFinanceManager_Client.zip	Email 08	Compressed archive (2.4 MB) requesting PII / malware payload.
Email	claims.department009@yandexmail.com	Email 10	Lottery scam sender address.
Email	agent.williams.claims@outlook-verify.info	Email 10	Lottery scam Reply-To address.
Email	s.iyer.cfo.travel@outlook.com	Email 11	External Outlook Reply-To address for CFO gift card scam (BEC).
Filename	Pending_Invoice_Challan_Details.docm	Email 13	Macro-enabled Word document containing malicious VBA payload.
URL	shreeganesh-logistics.in.invoice-view-secure.com	Email 13	Malicious payload download domain.

5. OSINT & Cross-Verification Tools

To validate technical anomalies, domains, IP reputation, and file hashes, the following industry-standard OSINT and threat intelligence tools were utilized during the investigation:

- **VirusTotal:** Used to check reputation and detection ratios for suspicious domains, URLs, and attachment file hashes.
- **urlscan.io:** Used to safely inspect phishing landing pages and redirection chains without interacting with active threats.
- **MXToolbox:** Used to inspect DNS records, MX records, SPF validation, and sender IP blacklists.
- **Google Safe Browsing / PhishTank:** Used to cross-reference known phishing and malware distribution domains.
- **WHOIS / IP Geolocation:** Used to identify registrar details, domain creation dates (identifying newly registered typosquatted domains), and hosting ASNs (detecting free email relays and VPN exit nodes).

6. Recommendations & Preventive Controls

Based on the multi-vector threats uncovered in this investigation, Solvex Industries Pvt. Ltd. should immediately implement the following organizational and technical security controls:

1. **Email Authentication Enforcement:** Enforce strict DMARC policy ('p=reject') across all corporate domains to prevent spoofing and domain impersonation.
2. **Advanced Email Gateway (SEG) Filtering:** Deploy AI-driven SEGs capable of detecting Reply-To vs. From mismatches, display name spoofing, typosquatted domains, and anomalous external routing.
3. **Macro & Archive Controls:** Block incoming macro-enabled Office documents ('.docm', '.xlsm') and restricted archive formats ('.zip', '.iso') at the mail gateway unless explicitly required and scanned.
4. **Out-of-Band Verification Protocols:** Implement mandatory multi-factor out-of-band verification (e.g., phone call on known internal extension) for any request involving bank account changes, wire transfers, or gift card purchases.
5. **Continuous Employee Security Awareness:** Mandate regular phishing simulation exercises and interactive training (such as the Q3 InfoSec module) to ensure staff immediately report suspicious urgencies and credential prompts.